

9. Diseño básico de seguridad

Autenticación

- Inicio de sesión con usuario y contraseña; emisión de **token JWT** con expiración de 30 minutos y endpoint de renovación (`/api/auth/refresh`).
- Contraseñas cifradas con **BCrypt** (costo 12); nunca se almacenan en texto plano.
- Tokens enviados en el header `Authorization: Bearer <token>` (no en cookies, para simplificar el control en la SPA y en Swagger).

Manejo de credenciales y API keys (variables de entorno)

- Todas las claves (API key de IA, credenciales de BD, secretos JWT) se cargan desde **variables de entorno** a través de un archivo `.env` que **no se sube al repositorio**.
- Se publica únicamente una plantilla `env.example` con nombres de variables sin valores reales.
- `.gitignore` excluye `.env`, `*.pem`, claves y credenciales.

Validación de archivos subidos

- Filtro por extensión permitida (PDF, DOCX, TXT, JPG, PNG).
- Verificación de **tipo MIME** y de **magic bytes** (cabecera real del archivo) para rechazar ejecutables o archivos renombrados maliciosamente.
- Límite de tamaño de 25 MB; los archivos rechazados no se almacenan.

Control de acceso por rol (RBAC)

- Roles: `admin`, `gestor`, `consultor`.
- Reglas principales:
 - `consultor`: solo lectura, búsqueda, consulta RAG y descarga.
 - `gestor`: además carga y corrección de clasificación/metadatos.
 - `admin`: además gestión de usuarios, auditoría y dashboard completo.
- El backend valida el rol en cada endpoint (no solo el frontend) y responde 403 ante accesos no autorizados.
- Auditoría de acciones sensibles (login, carga, edición, descarga, eliminación, gestión de usuarios).